Microsoft Defender “RedSun” zero-day PoC grants SYSTEM privileges



Memori CTI

Overview

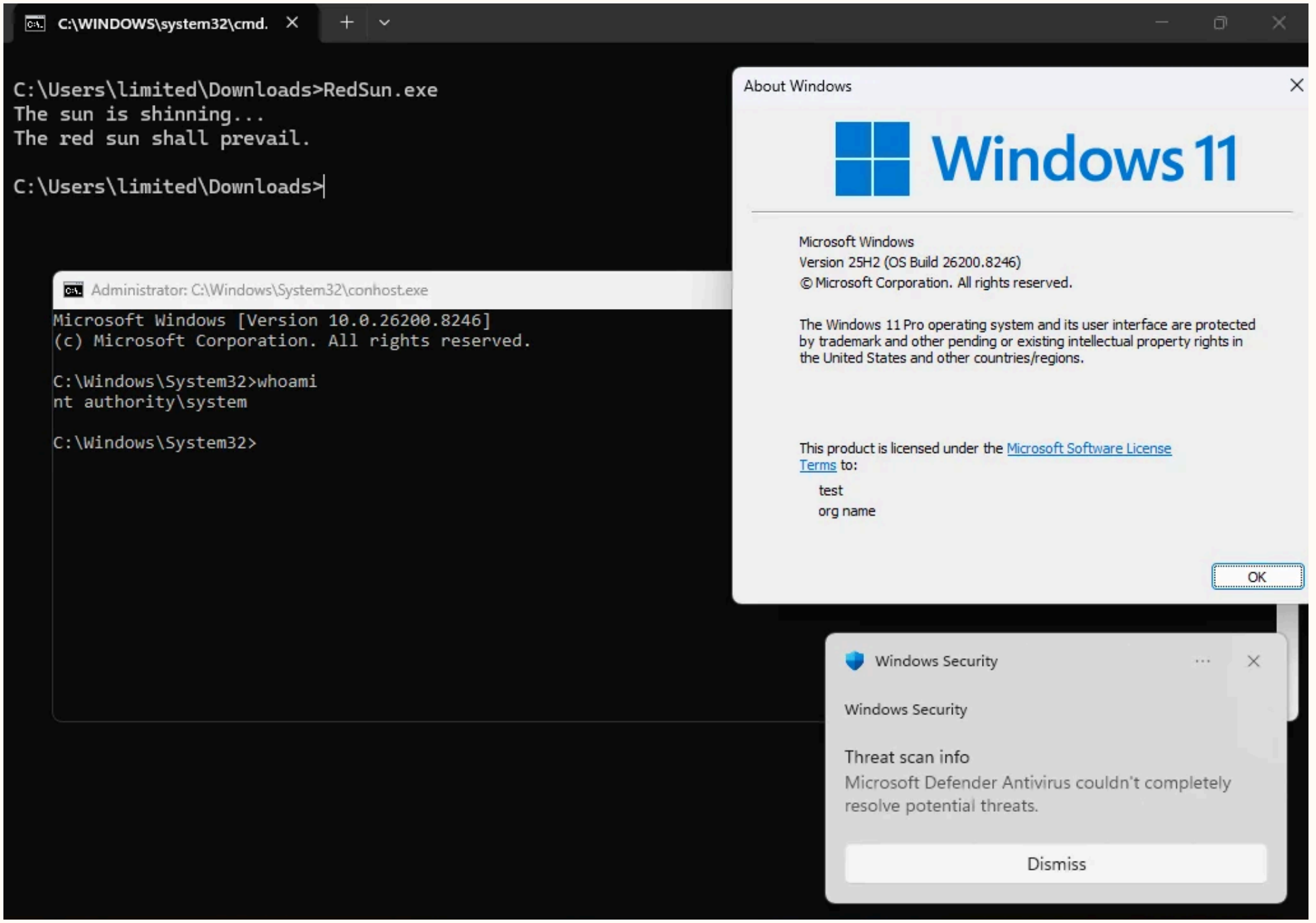
A cybersecurity researcher using the alias Chaotic Eclipse (aka Nightmare-Eclipse) has publicly released a PoC exploit for a new Microsoft Defender zero-day vulnerability. Dubbed **"RedSun"**, this flaw allows an attacker to perform a Local Privilege Escalation to gain full SYSTEM privileges. The exploit is confirmed to work on fully patched systems running Windows 10, Windows 11, and Windows Server 2019 and newer, provided Windows Defender is active.

Technical Mechanics

The vulnerability stems from a specific behavior within Windows Defender. When the antivirus detects a malicious file that includes a **"cloud tag"**, it attempts to rewrite that file back to its original location. The exploit manipulates this process through a specific chain of actions:

- **Cloud Files API:** The exploit utilizes this API to write an EICAR file, which is a standard antivirus test file.
- **Race Condition:** It uses an opportunistic lock (oplock) to win a race condition involving volume shadow copies.
- **Redirection:** By employing a directory junction or a reparse point, the attacker redirects the file rewrite process. Instead of overwriting the original location, the new contents are forced to overwrite a critical system executable located precisely at C:\Windows\system32\TieringEngineService.exe.
- **Execution:** Once the overwrite is complete, the Cloud Files Infrastructure executes the attacker-planted file. Because of the nature of the overwritten service, the malicious code runs with maximum SYSTEM privileges.

> Will Dormann, a principal vulnerability analyst at Tharros, verified the exploit's effectiveness. He also pointed out that while the initial code triggered antivirus alerts on VirusTotal due to the embedded **EICAR** string, encrypting that specific string significantly reduced detection rates.



Researcher's Motive

This incident marks the second zero-day exploit released by "Chaotic Eclipse" in just two weeks, following another privilege escalation flaw called **"BlueHammer"** (now tracked as CVE-2026-33825 and recently patched). The researcher stated that these public releases are a direct protest against the Microsoft Security Response Center. They allege that Microsoft heavily mistreated them during the vulnerability disclosure process, claiming the corporation ruined their life and engaged in unprofessional games rather than properly collaborating.

Microsoft's Response

> When contacted for a comment regarding the researcher's allegations, **Microsoft** provided a standard public relations statement. A spokesperson emphasized the company's commitment to investigating security reports, updating impacted devices swiftly, and supporting coordinated vulnerability disclosure practices to protect the broader community.